Università degli Studi di Roma Tor Vergata

Cybersecurity by Design for Critical Infrastructures

Laboratorio 1 e 2

Threat Modeling e Baseline di un Ospedale Digitale

Studenti:
Mihai Alexandru Sandu – Matricola 0378481
Matteo Sabelli – Matricola 0382089
Anno Accademico: 2025/2026

1 Introduzione

In questo laboratorio viene sviluppato un primo modello di sicurezza relativo a uno scenario di ospedale digitale. L'obiettivo è identificare gli asset principali del sistema, analizzare la superficie osservabile e collegare le possibili inferenze ai relativi scenari di attacco. L'analisi consente quindi di evidenziare i componenti più critici dell'infrastruttura e le principali aree di rischio.

2 Step 1 – Asset Inventory

In questo primo passo vengono identificati i principali asset presenti nello scenario di ospedale digitale. Per ciascun elemento si riportano la tipologia, il livello di criticità e le principali dipendenze operative e tecnologiche, così da ottenere una prima visione strutturata dell'infrastruttura.

Asset	**Tipo**	**Criticità**	**Dipendenze**
EHR Server	Server applicativo	Molto alta	DB EHR, rete interna, autenticazione
DB Cartelle Cliniche	Database	Molto alta	storage, EHR server, backup
Wi-Fi ospiti/pazienti	Rete wireless	Media	access point, controller, Internet
Dispositivi medici IoT/OT	Endpoint OT/IoT	Molto alta	rete OT, sistemi di supervisione, manutenzione
Sistema prenotazioni cloud	Servizio cloud	Alta	Internet, provider cloud, API
VPN medici remoti	Accesso remoto	Molto alta	gateway VPN, autenticazione, rete ospedale
Postazioni medici/infermieri	Endpoint IT	Alta	rete interna, EHR, credenziali
Sistema di autenticazione/Directory	Servizio infrastrutturale	Molto alta	server auth, rete interna
Firewall / gateway	Sicurezza perimetrale	Alta	configurazione, rete, policy

Tabella 1: Inventario iniziale degli asset principali dell'infrastruttura ospedaliera.

3 Step 2 – Superficie osservabile e inferenze

In questo secondo passo si analizza la superficie osservabile dei principali asset dell'infrastruttura, considerando esclusivamente gli elementi ricavabili dal comportamento delle comunicazioni e non dal contenuto del payload applicativo. L'obiettivo è individuare,

per ciascun componente, quali informazioni possano essere osservate e quali inferenze di sicurezza sia possibile trarre.

EHR Server

Per quanto riguarda l'EHR Server, è possibile osservare un traffico frequente verso il database, connessioni provenienti dalle postazioni cliniche, picchi di utilizzo nelle fasce orarie lavorative ed eventuali errori o meccanismi di retry nelle comunicazioni con il DB. Da questi elementi si può inferire che l'EHR costituisca un asset centrale nel flusso clinico, che esistano finestre temporali di massimo utilizzo e che vi sia una forte dipendenza operativa dal database. Inoltre, un aumento di latenze o retry può suggerire la presenza di degrado del servizio o di fault.

DB Cartelle Cliniche

Nel caso del database delle cartelle cliniche, si possono osservare numerose richieste provenienti dal server EHR, un traffico continuo ma relativamente prevedibile e connessioni generalmente limitate a pochi host autorizzati. Tali elementi permettono di inferire che il database rappresenti un backend critico dell'infrastruttura e che il suo comportamento segua un pattern sufficientemente regolare. Proprio per questo, eventuali deviazioni dalla baseline o la comparsa di nuove sorgenti di traffico possono costituire un indicatore di compromissione o di accessi anomali.

Wi-Fi ospiti/pazienti

Il Wi-Fi dedicato a ospiti e pazienti presenta tipicamente un numero elevato di dispositivi connessi, traffico prevalentemente diretto verso Internet, una forte variabilità nei flussi e, potenzialmente, tentativi di scansione verso indirizzi interni. Da queste osservazioni si può dedurre che questa rete sia molto più rumorosa e meno stabile come baseline rispetto alle altre componenti dell'ospedale. Inoltre, essa può costituire un possibile punto di partenza per attività di scanning; la presenza di traffico verso asset clinici interni potrebbe infatti indicare una violazione della segmentazione di rete.

Dispositivi medici IoT/OT

I dispositivi medici IoT/OT mostrano in genere un traffico molto regolare e periodico, comunicano con un numero ristretto di sistemi specifici e presentano frequenze di interazione abbastanza prevedibili. Possono inoltre emergere retry o latenze anomale. Queste caratteristiche rendono la baseline di tali dispositivi particolarmente ben definibile. Di conseguenza, un aumento della frequenza dei messaggi, del jitter o dei retry può indicare condizioni di fault, stress operativo o possibili attacchi. In questo contesto, fenomeni come DoS, scanning o lateral movement risultano particolarmente rilevanti.

Sistema prenotazioni cloud

Per il sistema di prenotazioni in cloud si osservano principalmente traffico HTTPS verso endpoint esterni, sincronizzazioni periodiche, una forte dipendenza dalla connettività Internet ed eventuali rallentamenti o timeout. Da tali elementi si può inferire la presenza di una dipendenza significativa da servizi esterni e dalla disponibilità del provider cloud. Inoltre, eventuali variazioni nei pattern di traffico o nelle destinazioni raggiunte possono suggerire problemi di disponibilità oppure possibili attacchi rivolti alle API o alle credenziali di accesso.

VPN medici remoti

La VPN utilizzata dai medici remoti consente di osservare finestre temporali di accesso, numero di sessioni attive, origini geografiche o di rete, durata delle connessioni ed eventuali fallimenti di login o retry. Da queste informazioni si può inferire l'esistenza di finestre operative ricorrenti associate all'attività dei medici. Un aumento degli errori di autenticazione può essere indicativo di tentativi di brute force o credential stuffing, mentre variazioni anomale negli orari, nelle provenienze o nella durata delle sessioni possono segnalare accessi non legittimi o comportamenti anomali.

Postazioni medici/infermieri

Le postazioni utilizzate da medici e infermieri mostrano connessioni frequenti verso l'EHR Server, accessi ai servizi di autenticazione e un'attività generalmente concentrata nelle fasce orarie di lavoro. Possono inoltre emergere variazioni nei volumi di traffico o connessioni effettuate fuori orario. Da queste osservazioni si può inferire che tali endpoint costituiscano un punto operativo centrale per l'utilizzo dei servizi clinici e che eventuali deviazioni rispetto alla normale operatività possano indicare uso improprio degli account, compromissione dell'host o tentativi di accesso non autorizzato.

Sistema di autenticazione/Directory

Il sistema di autenticazione e directory consente di osservare richieste di login provenienti da diversi asset interni, frequenza delle autenticazioni, eventuali fallimenti di accesso e picchi di utilizzo in corrispondenza degli orari di inizio attività. Tali elementi permettono di inferire che questo componente rappresenti un servizio infrastrutturale centrale e trasversale all'intera architettura. Un aumento anomalo dei tentativi falliti o richieste provenienti da sorgenti insolite può suggerire attività di brute force, errori di configurazione oppure possibili compromissioni.

Firewall / gateway

Il firewall o gateway perimetrale rende osservabili i flussi in ingresso e in uscita dall'infrastruttura, i principali servizi esposti, le destinazioni esterne contattate e l'eventuale presenza di traffico anomalo o non previsto. Da tali osservazioni si può inferire che questo asset costituisca un punto privilegiato di controllo e monitoraggio del perimetro di rete. Variazioni nei pattern di traffico, nuove destinazioni o tentativi ripetuti di accesso possono indicare attività di scanning, esposizioni indesiderate o tentativi di compromissione provenienti dall'esterno.

4 Step 3 – Dall'osservazione all'attacco

In questo passo, le osservazioni raccolte vengono collegate a possibili inferenze di sicurezza e ai relativi scenari di attacco. L'obiettivo è mostrare come determinati comportamenti osservabili possano costituire indicatori utili per individuare anomalie, compromissioni o tentativi di attacco.

Asset	**Osservabile**	**Inferenza**	**Attacco**
VPN medici remoti	molti tentativi falliti di autenticazione	possibile tentativo automatizzato sulle credenziali	brute force / credential stuffing
Wi-Fi ospiti	traffico verso host interni non previsti	tentativo di esplorazione della rete interna	scanning / lateral movement
EHR Server	aumento improvviso di latenze e retry verso DB	degrado del backend o sovraccarico anomalo	DoS applicativo o fault indotto
DB cartelle cliniche	nuove connessioni da host non usuali	accesso fuori baseline	compromissione interna / esfiltrazione
Dispositivi medici IoT/OT	variazione della periodicità di invio	comportamento anomalo rispetto alla baseline	manomissione, malware, DoS
Prenotazioni cloud	traffico verso endpoint esterni diversi dal solito	cambiamento di dipendenze o destinazioni	abuso API, supply-chain issue
Postazioni cliniche	traffico anomalo fuori orario	uso improprio account o host compromesso	accesso abusivo / movimento laterale

Tabella 2: Collegamento tra osservabili, inferenze e possibili scenari di attacco.

5 Step 4 – Grafo dell'infrastruttura

In questo passo l'infrastruttura viene rappresentata mediante un grafo, in cui i nodi corrispondono ai principali asset del sistema e gli archi descrivono le comunicazioni rilevanti tra essi. Questa rappresentazione consente di definire una baseline topologica iniziale e di evidenziare con maggiore chiarezza le relazioni operative, i punti di accesso e i possibili percorsi di propagazione del rischio.

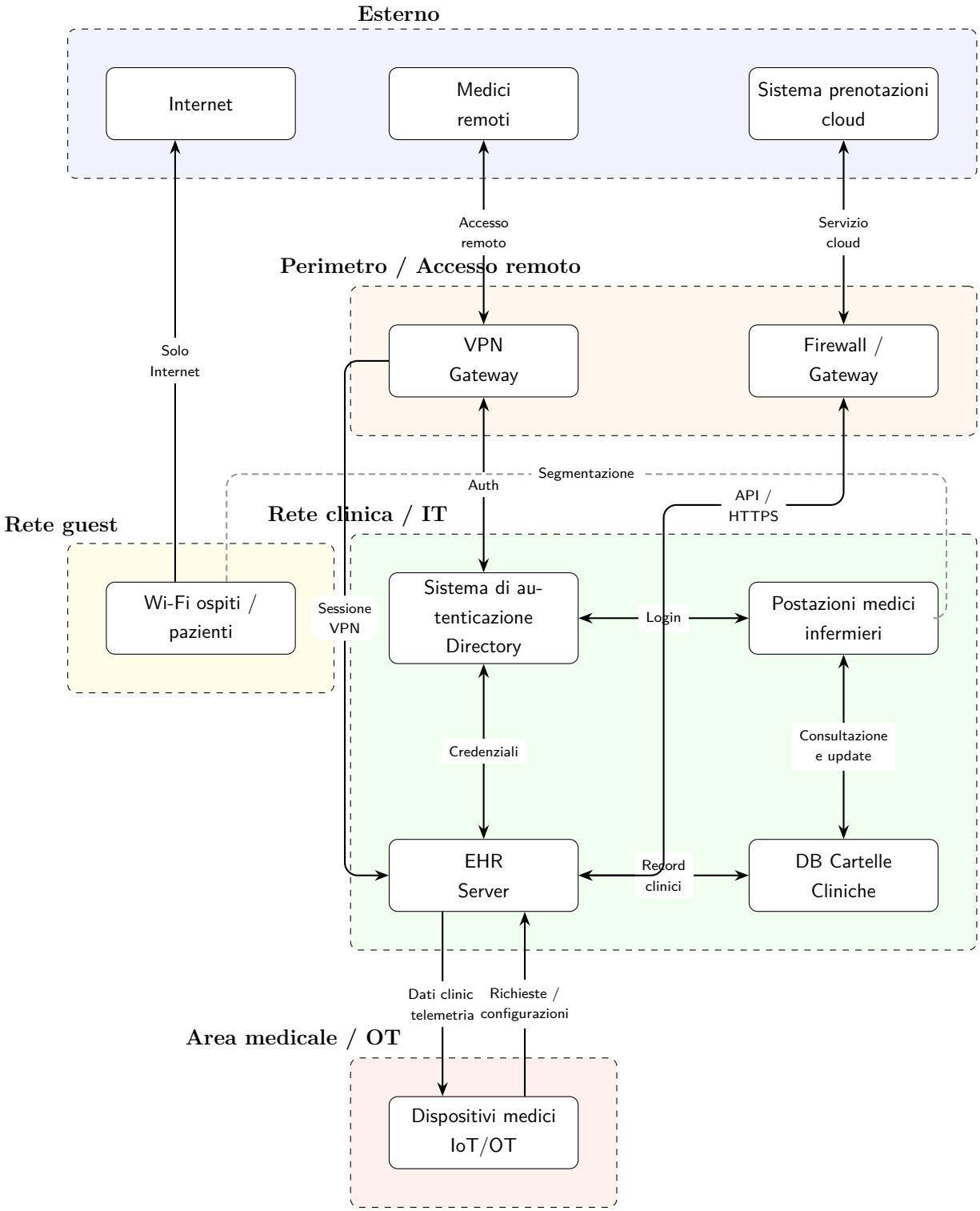

Figura 1: Grafo dell'infrastruttura dell'ospedale digitale con principali asset, comunicazioni e separazione in zone logiche. Il collegamento tra rete clinica e area medicale è rappresentato mediante due flussi direzionali distinti.

Il grafo rappresenta i principali asset dell'infrastruttura e i relativi collegamenti operativi. Emergono con chiarezza i nodi centrali, in particolare l'EHR Server e il database delle cartelle cliniche, i punti di accesso dall'esterno, come la VPN e il sistema di prenotazioni

cloud, e la separazione tra rete guest e rete clinica. Tale segmentazione è fondamentale per ridurre il rischio di scanning, movimento laterale e propagazione di eventuali compromissioni.

6 Debrief finale del Laboratorio 1

In questa sezione finale si sintetizzano i principali risultati emersi dall'attività di threat modeling del Laboratorio 1, mettendo in evidenza gli asset più rilevanti, i punti di maggiore osservabilità e le priorità di intervento dal punto di vista della security by design.

1. Asset più critico

L'asset più critico dell'infrastruttura è il sistema composto da *EHR Server* e *DB Cartelle Cliniche*. In particolare, il database rappresenta il punto centrale per la conservazione delle informazioni cliniche, mentre l'EHR costituisce il nodo applicativo essenziale per l'accesso e la gestione operativa di tali dati. Un malfunzionamento o una compromissione di questi componenti avrebbe un impatto diretto sulla continuità del servizio sanitario e sul corretto svolgimento delle attività cliniche.

2. Asset più osservabile

L'asset maggiormente osservabile è la *VPN per i medici remoti*. Infatti, questo componente espone in modo naturale diversi elementi misurabili, come orari di accesso, numero di sessioni, provenienza delle connessioni, durata delle sessioni ed eventuali errori di autenticazione. Tali osservabili rendono la VPN particolarmente adatta alla definizione di una baseline comportamentale e all'individuazione di anomalie.

3. Asset più pericoloso come pivot

L'asset più pericoloso come possibile punto di pivot è il *Wi-Fi ospiti/pazienti*. Pur non essendo direttamente parte del nucleo clinico, esso rappresenta una superficie esposta, rumorosa e potenzialmente utile per attività di scanning o tentativi di accesso verso segmenti interni. In assenza di una corretta segmentazione, questa rete potrebbe diventare un punto di partenza per fenomeni di lateral movement verso asset più sensibili.

4. Primo controllo by design da introdurre

Il primo controllo by design da introdurre dovrebbe essere una **segmentazione forte dell'infrastruttura in zone logiche**, accompagnata da regole di comunicazione ristrette tra le varie aree del sistema. In particolare, risulta fondamentale separare in modo netto la rete guest dalla rete clinica e definire conduits controllati per l'accesso remoto, per

i servizi cloud e per i dispositivi medici IoT/OT. Questa scelta consente di ridurre la superficie di attacco, rendere più chiari i comportamenti attesi e facilitare il rilevamento delle deviazioni rispetto alla baseline.

Chiusura

L'analisi svolta nel Laboratorio 1 mostra che la sicurezza dell'ospedale digitale non dipende soltanto dalla presenza di controlli tecnici, ma soprattutto dalla capacità di modellare correttamente asset, dipendenze, flussi e comportamenti attesi. In questo senso, il threat modeling rappresenta il primo passo per trasformare un'infrastruttura complessa in un sistema osservabile, comprensibile e difendibile.

7 Laboratorio 2 – From Model to Baseline

Il secondo laboratorio riprende il modello costruito nel Laboratorio 1 e lo rende operativo dal punto di vista decisionale. L'obiettivo non è più soltanto descrivere asset, osservabili e possibili attacchi, ma definire una **baseline comportamentale** dell'infrastruttura e verificare se una nuova finestra osservata sia compatibile con il comportamento atteso oppure costituisca una deviazione significativa.

In altre parole, il modello del Laboratorio 1 viene trasformato in un *operating envelope*: un insieme di relazioni, orari, intensità e vincoli topologici ammessi. Ogni evento osservato viene quindi confrontato con questo inviluppo operativo, così da poter distinguere in maniera ragionata tra comportamento normale, anomalia, fault, manutenzione, attacco oppure situazione ancora non classificabile.

7.1 Step 2 – Baseline comportamentale

Per definire la baseline qualitativa dell'ospedale digitale sono state selezionate le relazioni più significative del modello. Per ciascuna di esse si specifica se la comunicazione sia normale o meno, quando sia attesa, con quale intensità e con quale interpretazione operativa.

Relazione	Normale	Quando	Intensità attesa	Note
VPN medici remoti → EHR Server	Sì	Giorno; notte solo in reperibilità/emergenza	Media	Accesso remoto ai servizi clinici da parte del personale autorizzato
EHR Server → DB Cartelle Cliniche	Sì	Sempre	Alta	Backend applicativo centrale dell'infrastruttura
Dispositivi medici IoT/OT → EHR Server	Sì	Sempre	Media	Invio di dati clinici, eventi o sincronizzazioni verso il sistema centrale
EHR Server → Sistema prenotazioni cloud	Sì	Sempre	Media	Sincronizzazioni API e interazione con il servizio di prenotazione
EHR Server → Backup	Sì	Notte	Alta	Backup schedulato dei dati applicativi e clinici
Backup → EHR Server	Sì	Notte	Bassa/Media	Conferme, verifiche di consistenza ed eventuali operazioni di restore
Wi-Fi ospiti/pazienti → EHR Server	No	Mai	Nulla	Violazione topologica: la rete guest non deve raggiungere la rete clinica
UnknownHost → EHR Server	No	Mai	Nulla	Nodo non censito nell'inventario iniziale
Dispositivi medici IoT/OT → DB Cartelle Cliniche	No	Mai	Nulla	I dispositivi non devono accedere direttamente al database clinico
DB Cartelle Cliniche → UnknownHost	No	Mai	Nulla	Comunicazione non prevista, potenzialmente compatibile con pivot o esfiltrazione

Tabella 3: Baseline comportamentale qualitativa delle principali relazioni del modello.

La baseline definita non è puramente volumetrica, ma combina più dimensioni: topologia delle comunicazioni, finestra temporale, intensità attesa e ruolo funzionale della relazione. In questo modo, una stessa comunicazione può risultare compatibile in una certa fascia oraria e deviata in un'altra, oppure essere ritenuta critica già per il solo fatto di comparire tra due nodi che non dovrebbero comunicare.

7.2 Step 3 – Finestra osservata

Una volta definita la baseline, si analizza la finestra osservata assegnata. Nel dataset seguente:

- *Device1* e *Device2* rappresentano dispositivi medici della zona IoT/OT;
- *BookingCloud* corrisponde al sistema di prenotazioni cloud;
- *Backup* rappresenta il servizio di supporto utilizzato per il salvataggio notturno;
- *UnknownHost* indica un nodo non censito nel modello iniziale.

L'obiettivo non è cercare l'attacco in astratto, ma confrontare ciascun evento con la baseline appena costruita.

Tabella 4: Finestra osservata del Laboratorio 2 applicata al modello dell'ospedale digitale.

Time	**Source**	**Dest**	**Proto**	**Pkts**	**Status**
08:10	VPN	EHR	TLS	145	ok
08:11	EHR	DB	TCP	240	ok
08:12	Device1	EHR	TLS	62	ok
08:13	Device2	EHR	TLS	59	ok
08:14	EHR	BookingCloud	HTTPS	95	ok
08:16	GuestWiFi	EHR	TCP	18	ok
08:17	UnknownHost	EHR	TCP	27	fail
08:18	VPN	EHR	TLS	310	retry
08:19	EHR	DB	TCP	520	ok
08:20	Device1	DB	TCP	44	ok
02:05	EHR	Backup	TCP	980	ok
02:07	Backup	EHR	TCP	155	ok
02:09	VPN	EHR	TLS	88	ok
02:10	EHR	BookingCloud	HTTPS	140	ok
02:11	DB	UnknownHost	TCP	160	ok

7.3 Step 4 – Valutazione preliminare delle deviazioni

In questa fase si misura la distanza tra ciascun evento osservato e la regione di comportamento atteso. La classificazione qui proposta è ancora preliminare: non tutte le deviazioni sono necessariamente attacchi, poiché in un'infrastruttura critica una variazione può dipendere anche da fault, manutenzione o semplice mancanza di contesto.

Tabella 5: Valutazione preliminare delle deviazioni rispetto alla baseline.

Evento	**Comp.**	**Score**	**Classificazione preliminare**	**Motivazione**
08:10 VPN → EHR	Sì	Basso	Normale	Accesso remoto diurno coerente con la baseline dei medici remoti.
08:11 EHR → DB	Sì	Basso	Normale	Relazione core del backend applicativo, prevista sempre e con intensità alta.
08:12 Device1 → EHR	Sì	Basso	Normale	Comunicazione coerente con il ruolo dei dispositivi medici verso il sistema centrale.
08:13 Device2 → EHR	Sì	Basso	Normale	Stesso comportamento atteso del caso precedente, senza segnali di deviazione.
08:14 EHR → Booking-Cloud	Sì	Basso	Normale	Sincronizzazione con il sistema di prenotazioni cloud compatibile con la baseline.
08:16 GuestWiFi → EHR	No	Alto	Attacco	Violazione topologica netta: la rete guest non deve mai raggiungere l'EHR. Anche con volume basso, la deviazione è forte.
08:17 UnknownHost → EHR	No	Alto	Attacco	Nodo non censito che tenta di raggiungere l'EHR; il *fail* suggerisce probing, scansione o blocco da parte di un controllo.
08:18 VPN → EHR (*retry*)	Sì	Medio	Unknown	La relazione è attesa, ma il volume cresce e compaiono retry: potrebbe trattarsi di congestione, fault o abuso di credenziali.
08:19 EHR → DB	Sì	Basso	Normale	Intensità elevata ma ancora compatibile con una relazione strutturalmente alta nella baseline.
08:20 Device1 → DB	No	Alto	Unknown	Percorso non previsto nel modello: potrebbe indicare bypass dell'EHR, misconfigurazione o integrazione del vendor non censita.
02:05 EHR → Backup	Sì	Basso	Normale	Flusso notturno coerente con il backup schedulato.
02:07 Backup → EHR	Sì	Basso	Normale	Risposta o verifica di consistenza compatibile con il processo di backup.
02:09 VPN → EHR	Sì	Basso	Unknown	Accesso notturno compatibile solo se riferibile a reperibilità medica o emergenza clinica.
02:10 EHR → Booking-Cloud	Sì	Basso	Normale	Sincronizzazione notturna plausibile per un servizio cloud che opera in continuità.
02:11 DB → UnknownHost	No	Alto	Attacco	Il database clinico non deve instaurare connessioni verso nodi sconosciuti; pattern compatibile con pivot o esfiltrazione.

7.4 Step 5 – Classificazione finale e dato utile

Poiché la decisione viene presa in condizioni di osservabilità parziale, per ogni evento si riporta anche il *dato utile* che consentirebbe di ridurre l'incertezza residua. Questo passaggio è essenziale soprattutto per i casi classificati come *Unknown*, nei quali l'evidenza disponibile non basta ancora per sostenere una diagnosi definitiva.

Tabella 6: Classificazione finale degli eventi e dato utile per la decisione.

Evento	**Comp.**	**Score**	**Class. finale**	**Dato utile**
08:10 VPN → EHR	Sì	Basso	Normale	Nessuno: accesso diurno coerente con l'uso atteso della VPN.

Evento	Comp.	Score	Class. finale	Dato utile
08:11 EHR → DB	Sì	Basso	Normale	Nessuno: traffico fisiologico del backend applicativo.
08:12 Device1 → EHR	Sì	Basso	Normale	Nessuno: telemetria o invio dati compatibile con il ruolo del dispositivo.
08:13 Device2 → EHR	Sì	Basso	Normale	Nessuno: comportamento allineato alla baseline.
08:14 EHR → BookingCloud	Sì	Basso	Normale	Nessuno: sincronizzazione HTTPS attesa verso il cloud.
08:16 GuestWiFi → EHR	No	Alto	Attacco	Indirizzo IP e MAC del dispositivo guest, log del firewall e verifica che la rete guest sia davvero separata dalla rete clinica.
08:17 UnknownHost → EHR	No	Alto	Attacco	Identità del nodo sconosciuto, porta o servizio usato nella connessione, log dei sistemi di monitoraggio della rete e verifica di eventuali blocchi di rete.
08:18 VPN → EHR (*retry*)	Sì	Medio	Unknown	Log del punto di accesso VPN, identità dell'utente, indirizzo IP di provenienza, numero di accessi contemporanei e tempi di risposta dell'EHR.
08:19 EHR → DB	Sì	Basso	Normale	Nessuno: volume elevato ma ancora compatibile con una relazione critica e persistente.
08:20 Device1 → DB	No	Alto	Unknown	Inventario aggiornato del dispositivo, documentazione del fornitore, regole di accesso al database e registri applicativi del dispositivo.
02:05 EHR → Backup	Sì	Basso	Normale	Nessuno: traffico notturno coerente con il backup pianificato.
02:07 Backup → EHR	Sì	Basso	Normale	Nessuno: risposta prevista nel ciclo di backup.
02:09 VPN → EHR	Sì	Basso	Unknown	Turno di reperibilità, identità del medico e presenza di ticket o emergenza clinica associata all'accesso.
02:10 EHR → BookingCloud	Sì	Basso	Normale	Nessuno: sincronizzazione notturna plausibile con un servizio cloud sempre attivo.
02:11 DB → UnknownHost	No	Alto	Attacco	Quantità di dati trasferiti, identità del nodo destinatario, log delle interrogazioni al database ed eventuale traffico in uscita anomalo rilevato dal firewall.

7.5 Debrief finale del Laboratorio 2

Deviazione più grave. La deviazione più grave è l'evento *02:11 DB → UnknownHost*. In questo caso non si osserva soltanto una variazione di intensità o di timing, ma una violazione topologica diretta che coinvolge l'asset più critico del sistema, ossia il database delle cartelle cliniche. Una comunicazione dal DB verso un nodo sconosciuto, per di più in orario notturno, è fortemente compatibile con una possibile fuoriuscita di dati o con l'uso improprio di un sistema interno compromesso.

Deviazione più ambigua. La deviazione più ambigua è l'evento *08:18 VPN → EHR* con stato *retry*. La relazione in sé è lecita e attesa, ma la combinazione di volume più alto e retry non consente di distinguere immediatamente tra congestione, fault applicativo,

instabilità della VPN o abuso di credenziali. Si tratta quindi di un caso esemplare in cui la classificazione corretta è *Unknown* finché non si acquisisce ulteriore contesto.

Deviazione che richiede risposta immediata. L'evento che richiede risposta immediata è ancora *02:11 DB → UnknownHost*, seguito da *08:16 GuestWiFi → EHR*. Il primo può indicare un data breach in corso; il secondo evidenzia una violazione della segmentazione tra rete guest e rete clinica, che rappresenta un rischio strutturale elevato e va bloccato tempestivamente.

Quando la risposta corretta è *Unknown*. La risposta *Unknown* è corretta quando l'evento devia dalla baseline ma l'evidenza disponibile non basta per sostenere una classificazione affidabile. In questo dataset rientrano soprattutto:

- il picco con retry sulla VPN verso EHR, che può dipendere sia da fault sia da attività ostile;
- il flusso *Device1 → DB*, che può rappresentare sia un bypass anomalo sia una integrazione non censita;
- l'accesso notturno della VPN verso EHR, che in ospedale può essere compatibile con reperibilità o emergenza.

8 Conclusioni finali

Considerando congiuntamente i due laboratori, emerge una progressione metodologica chiara. Nel Laboratorio 1 l'infrastruttura è stata descritta in termini di asset, osservabili, inferenze e possibili attacchi; nel Laboratorio 2 quello stesso modello è stato trasformato in uno strumento decisionale, cioè in una baseline utile a distinguere tra comportamento ammesso e deviazione significativa.

Il risultato principale è che la sicurezza non dipende soltanto dalla capacità di vedere eventi di rete, ma soprattutto dalla possibilità di interpretarli all'interno di un modello coerente del sistema. Una comunicazione può infatti essere perfettamente normale, lievemente anomala oppure critica non in assoluto, ma in funzione di chi comunica con chi, in quale fascia oraria, con quale intensità e con quale significato operativo.

In conclusione, il contributo più importante del lavoro svolto è mostrare che il threat modeling e la definizione della baseline sono due fasi complementari dello stesso processo: prima si rende l'infrastruttura comprensibile, poi la si rende misurabile. Solo a quel punto è possibile prendere decisioni difendibili sotto incertezza, riducendo il rischio sia di falsi positivi operativamente costosi sia di falsi negativi potenzialmente critici per un contesto ospedaliero.